

Análisis de Vulnerabilidades

Identificar, puntuar y priorizar los fallos antes de que alguien los explote. CVE, CVSS, EPSS, KEV y un ciclo de vida que nunca termina.

• 17 diapositivas

~25 min

Nivel · Iniciación + Práctica



Qué vamos a ver

/01	Amenaza · vulnerabilidad · riesgo	conceptos
/02	CVE · el catálogo universal	MITRE
/03	CVSS · puntuar la severidad	FIRST
/04	NVD · CWE · KEV · EPSS	2 slides
/05	Pentest vs vulnerability assessment	diferencias
/06	Escáneres: Nessus, OpenVAS, Qualys	herramientas
/07	El ciclo de vida	PDCA
/08	Priorización inteligente	CVSS + EPSS + KEV
/09	Disclosure y CVE Numbering Authorities	CNA
/10	Lab · escaneo y triage	manos a la obra

Amenaza, vulnerabilidad, riesgo

Tres conceptos que se confunden a diario. Distinguirlos cambia la forma de comunicar y priorizar.

// AMENAZA

Amenaza

Cualquier evento o actor con potencial de causar daño: un ransomware, un insider, un fallo eléctrico.

eg. grupo APT activo

// VULNERABILIDAD

Vulnerabilidad

Debilidad concreta en un sistema que una amenaza podría aprovechar. Suele tener un identificador (CVE).

eg. SMBv1 sin parchear

// RIESGO

Riesgo

Producto de la probabilidad por el impacto. Lo que de verdad gestiona la dirección.

eg. cifrado de archivos

$\text{riesgo} = \text{amenaza} \times \text{vulnerabilidad} \times \text{impacto}$

CVE · Common Vulnerabilities and Exposures

Identificador único y público para cada vulnerabilidad conocida.
Lo gestiona MITRE desde 1999.

CVE-2021-44228

Apache Log4j · "Log4Shell"

Inyección JNDI vía LDAP en la librería Log4j 2.x. Permite ejecución remota de código simplemente registrando una cadena controlada por el atacante. Considerado uno de los CVE de mayor impacto de la historia. [1]

publicado	10 dic 2021
producto	Apache Log4j 2.0 - 2.14.1
CVSS v3.1	10.0 · CRITICAL
CWE	CWE-502 · CWE-917
KEV (CISA)	SÍ · explotada en activo
EPSS	0,97 (P95)

▲ Un CVE no dice "está roto y ya". Dice "este componente, esta versión, esta debilidad concreta, esta puntuación".

CVSS • cómo se puntúa

Common Vulnerability Scoring System. Da un número de 0 a 10 que ayuda a comparar manzanas con manzanas. Lo mantiene FIRST.

// NONE

0.0

Informativo. Sin impacto técnico real.

// LOW

0.1 – 3.9

Impacto limitado o condiciones difíciles de cumplir.

// MEDIUM

4.0 – 6.9

Vulnerabilidad real pero explotable con esfuerzo notable.

// HIGH

7.0 – 8.9

Explotable con relativa facilidad. Prioridad alta.

// CRITICAL

9.0 – 10.0

Compromiso total o RCE remoto sin autenticación. Parchea ya.

3 grupos de métricas: Base (qué es la vuln • obligatoria) • Temporal (madurez del exploit) • Environmental (ajuste a tu organización).

Qué dice cada letra

Explotabilidad

// cómo se ataca

AV · Attack Vector

N network · A adjacent · L local · P physical

AC · Attack Complexity

L baja · H alta (depende de condiciones)

PR · Privileges Required

N ninguno · L usuario · H admin

UI · User Interaction

N no requiere · R requiere acción del usuario

Impacto

// qué se rompe

S · Scope

U unchanged · C changed (afecta más allá)

C · Confidentiality

N none · L low · H high

I · Integrity

N none · L low · H high

A · Availability

N none · L low · H high

NVD y CWE

NVD

// nvd.nist.gov

qué es	National Vulnerability Database del NIST. Enriquece cada CVE con CVSS, CPE y referencias.
acceso	Web + API JSON 2.0 · feeds gratuitos para SCA y SIEM.
CPE	Common Platform Enumeration · identificador estándar del producto afectado.
cifras 2023	~ 28.000 CVEs nuevos publicados · récord histórico. [2]

CWE

// cwe.mitre.org

qué es	Common Weakness Enumeration. Categoriza las clases de error que producen vulnerabilidades.
ejemplos	CWE-79 XSS · CWE-89 SQLi · CWE-22 path traversal · CWE-787 out-of-bounds write
Top 25	Lista anual de las debilidades más peligrosas. Útil para priorizar formación y diseño.
relación	Un CVE concreto pertenece a una o más CWEs.

KEV y EPSS · señales de explotación real

CVSS te dice cuán grave podría ser. Estas dos fuentes te dicen cuán probable es **hoy**.

KEV // CISA		EPSS // FIRST	
qué es	Known Exploited Vulnerabilities. Catálogo oficial de la agencia CISA con CVEs explotados en ataques reales.	qué es	Exploit Prediction Scoring System. Modelo ML que estima la probabilidad de explotación a 30 días.
cuándo entra	Cuando hay evidencia confirmada de explotación activa. No por temor.	salida	Puntuación 0.00 - 1.00 + percentil. Se actualiza a diario.
obligación	Agencias federales USA: parchear en plazo. Resto: úsalo como prioridad cero.	cómo usarlo	Para priorizar: un CVSS 9.8 con EPSS 0,01 puede esperar más que un CVSS 7.5 con EPSS 0,95.
tamaño	Crece varios CVE/semana. ~1.000+ entradas vigentes.	acceso	API gratuita en first.org/epss · CSV diario.

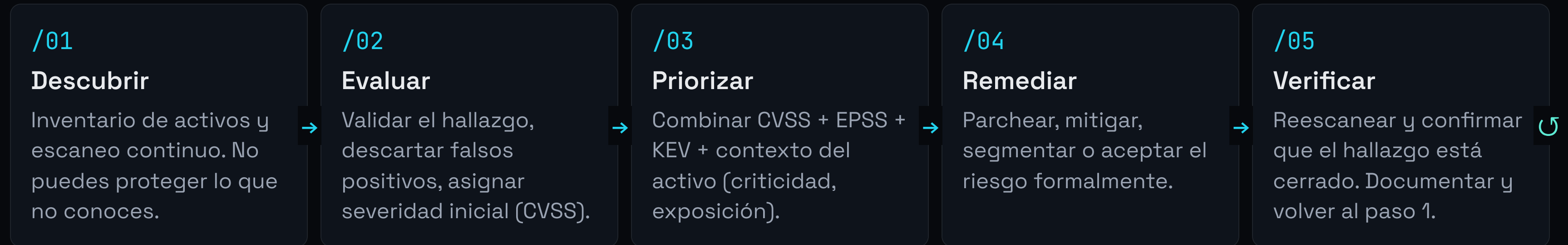
Pentest vs Vulnerability Assessment

DIMENSIÓN	VULNERABILITY ASSESSMENT	PENETRATION TEST
objetivo	Identificar tantas vulns como sea posible.	Demostrar impacto real explotando una cadena.
profundidad	Amplio y superficial.	Limitado pero profundo.
automatización	Mayormente automatizado (escáner).	Manual con apoyo de herramientas.
explotación	No · sólo se detecta.	Sí · se intenta explotar lo encontrado.
cadencia	Continua o mensual.	Puntual · 1-2 al año + tras grandes cambios.
entregable	Listado priorizado de vulns.	Informe narrativo con escenarios y remediación.

Escáneres de vulnerabilidades

HERRAMIENTA	TIPO	LICENCIA	PENSADO PARA
Nessus	Red e infraestructura · clásico del mercado.	comercial · Pro	infra · servidores
OpenVAS / GVM	Versión open-source de Nessus original. Comunidad Greenbone.	open-source	infra · self-hosted
Qualys VMDR	Plataforma SaaS · gestión de vulns extremo a extremo.	comercial · SaaS	enterprise
Rapid7 InsightVM	Sucesor de Nexpose · alta integración con Metasploit.	comercial	enterprise
Trivy	Escaneo de contenedores, IaC y SBOM. Open-source.	open-source	DevSecOps · containers
Burp Suite	Específico para aplicaciones web · estándar de WebApp pentest.	comercial / Comm	webapp · API

Ciclo de gestión de vulnerabilidades



▲ NIST CSF lo formaliza en las funciones **Identify • Protect • Detect • Respond • Recover**. ISO 27001 lo enmarca como mejora continua (PDCA).

Priorización inteligente

Con miles de CVEs por mes, decidir qué tocar primero es **el** problema. Combina varias señales, no solo el CVSS.

[01]Activo crítico · ¿está en un sistema con datos sensibles o cara a Internet?	contexto
[02]CVSS Base · severidad técnica intrínseca. Punto de partida.	CVSS
[03]KEV (CISA) · si está en KEV, sube al tope. Hay actores explotándolo hoy.	KEV
[04]EPSS · probabilidad de explotación en los próximos 30 días.	EPSS
[05]Disponibilidad de parche · existe upgrade vs solo workaround.	fix
[06]Compensating controls · ¿tienes WAF, EDR o segmentación que lo mitigue?	defense
[07]SLA por severidad · crítico 7 días, alto 30, medio 90. Firmado con el negocio.	policy

Disclosure responsable

Si descubres una vulnerabilidad, hay un protocolo. Reventarla en Twitter sin avisar es ilegal y daña a usuarios reales.

/01

Notificar al vendor

security@empresa.com o programa de bug bounty. Detalle técnico, PoC y datos de contacto.

canal · cifrado PGP

**/02**

Ventana de gracia

Acuerdo de plazo (típicamente 90 días, Project Zero). Tiempo para parchear sin presión pública.

**/03**

Asignar CVE

A través de una **CNA** (CVE Numbering Authority). Coordina MITRE.

**/04**

Publicar advisory

Una vez existe parche: vendor publica, investigador publica detalles, NVD enriquece, el mundo parchea.

coordinated · ISO/IEC 29147

▲ En España, INCIBE-CERT tiene su procedimiento de notificación coordinada. Para infra crítica, CCN-CERT también acepta avisos.

Errores comunes

“Parcheamos sólo lo crítico”

Confiar únicamente en CVSS deja explotaciones reales (KEV) sin tocar si pillan en CVSS 7.

solución · CVSS + EPSS + KEV

Escaneo sin inventario

Si no sabes qué activos tienes, el escaneo deja huecos enormes (shadow IT, IoT, cloud).

solución · CMDB + descubrimiento continuo

Reporte sin contexto

PDF de 800 hallazgos sin priorizar. El equipo de IT se rinde antes de empezar.

solución · top 20 + plan + dueño

Sin SLAs por severidad

Sin plazos firmados, las críticas duermen meses junto a las informativas. “Marcamos como fixed” no significa que lo esté: reescanea siempre.

solución · política firmada + reescaneo

Escanea Metasploitable2 y prioriza

```
// scanner  
Kali Linux  
172.X.X.X
```

```
docker bridge ·  
172.X.X.X/16
```

```
// target  
Metasploitable2  
172.X.X.X
```

TU MISIÓN

- › Lanzar un escaneo de vulnerabilidades.
- › Mapear cada hallazgo a su **CVE** y **CVSS**.
- › Consultar **CISA KEV** y **EPSS** para 3 de ellos.
- › Construir un top-3 priorizado y justificarlo.

```
●●● kali@kali · ~/lab-05 · bash
```

[01] Escanea Metasploitable2 con scripts de vulnerabilidades:
\$ `nmap -sV --script vuln -oN /tmp/lab05.txt 172.X.X.X`
tarda 3-5 min – es normal

[02] Extrae los CVEs encontrados:
\$ `grep -E 'CVE-[0-9]+' /tmp/lab05.txt`
anota al menos 3 CVEs distintos con su servicio y puerto

[03] Investiga cada CVE en NVD:
→ nvd.nist.gov/vuln/search · anota la puntuación CVSS y la categoría CWE

[04] Construye tu Top-3 priorizado (mayor → menor CVSS):
1. `CVE-XXXX-XXXX` · vsftpd · CVSS **10.0** · RCE sin autenticación
2. `CVE-XXXX-XXXX` · Samba · CVSS **7.5** · acceso a archivos
3. `CVE-XXXX-XXXX` · Apache · CVSS **5.0** · XSS

6 ideas para llevarte

- /01 **Amenaza ≠ vulnerabilidad ≠ riesgo**. Lo que se gestiona es riesgo: probabilidad × impacto.
- /02 **CVE** identifica · **CVSS** puntúa · **CWE** clasifica · **CPE** ubica.
- /03 CVSS solo no basta: **KEV** y **EPSS** aportan la señal de explotación real.
- /04 VA y pentest son **complementarios**: amplio y automático vs profundo y manual.
- /05 Es un **ciclo** · descubrir → evaluar → priorizar → remediar → verificar → repetir.
- /06 Si tú encuentras la vuln: **disclosure responsable**, no Twitter.

SIGUIENTE · TEMA 06

Ingeniería Social

El humano sigue siendo el eslabón más explotado. Phishing, pretexting, baiting y cómo entrenar a las personas para detectarlo.

→ continúa en el siguiente vídeo

Para profundizar

Todos los catálogos oficiales son gratuitos y consultables públicamente.

[1]	MITRE CVE	Catálogo oficial de CVE · cve.mitre.org · cve.org
[2]	NIST NVD	National Vulnerability Database · enriquecimiento CVE + CPE · nvd.nist.gov
[3]	FIRST CVSS / EPSS	CVSS v3.1 / v4.0 Specification · EPSS · first.org/cvss · first.org/epss
[4]	CISA KEV	Known Exploited Vulnerabilities Catalog · cisa.gov/kev
[5]	MITRE CWE	Common Weakness Enumeration + CWE Top 25 · cwe.mitre.org
[6]	Estándares	NIST SP 800-30, 800-115, CSF 2.0 · ISO/IEC 27005, 29147, 30111 · INCIBE-CERT